SecureDrop Next Generation:
Lessons from a Decade of Deployment

Giulio Berra, Felix Linker, Luca Maier, Cory Francis Myers,
Kenneth G. Paterson, **Rowen Shane**, **Shannon Veitch**

Real World Crypto 2026

FREEDOM OF THE PRESS FOUNDATION ETH zürich

Major stories…

The Intercept_

THE ASSASSINATION COMPLEX

THE WALL STREET JOURNAL.

Facebook Knows Instagram Is Toxic for Teen Girls, Company Documents Show

Vast leak alleges Credit Suisse accounts held by corrupt officials and criminals

Propaganda Machine: Secret documents reveal Russia's foreign influence strategy across three continents

Massive Hack of 70 Million Prisoner Phone Calls Indicates Violations of Attorney-Client Privilege

'All lies': how the US military covered up gunning down two journalists in Iraq

Giant Leak of Offshore Financial Records Exposes Global Array of Crime and Corruption

The Intercept_

SNOWDEN DOCUMENTS REVEAL COVERT SURVEILLANCE AND PRESSURE TACTICS AIMED AT WIKILEAKS AND ITS SUPPORTERS

The Washington Post

Democracy Dies in Darkness

Trump recorded having extremely lewd conversation about women in 2005

Major stories…major risks for sources

The Intercept_

THE ASSASSINATION COMPLEX

Propaganda Machine: Secret documents reveal Russia's foreign influence strategy across three continents

The Intercept_

SNOWDEN DOCUMENTS REVEAL COVERT SURVEILLANCE AND PRESSURE TACTICS AIMED AT WIKILEAKS AND ITS SUPPORTERS

THE WALL STREET JOURNAL.

Facebook Knows Instagram Is Toxic for Teen Girls, Company Documents Show

Massive Hack of 70 Million Prisoner Phone Calls Indicates Violations of Attorney-Client Privilege

Vast leak alleges Credit Suisse accounts held by corrupt officials and criminals

'All lies': how the US military covered up gunning down two journalists in Iraq

Giant Leak of Offshore Financial Records Exposes Global Array of Crime and Corruption

The Washington Post

Democracy Dies in Darkness

Trump recorded having extremely lewd conversation about women in 2005

The Asahi Shimbun

Retired officer says he leaked info to expose police corruption

ALJAZEERA

Australian who blew whistle on alleged Afghan war crimes stands trial

THE BALTIMORE SUN

Judge refuses to dismiss espionage charge against NSA employee

INTERNATIONAL CONSORTIUM OF INVESTIGATIVE JOURNALISTS

ICIJ condemns conviction of LuxLeaks whistleblowers

POLITICO

Israeli lawyer and peacenik guilty of leaking FBI secrets

SPIEGEL International

"The Russian Government Wants To See Me Dead"

NBC NEWS

Chelsea Manning Set to Be Released From Prison, but Still Not Free

Kagoshima Police Whistleblower Charged with Confidentiality Breach

SECUREDROP

PROPUBLICA

SecureDrop Can Offer Extra Digital Security

The New York Times

SecureDrop

SPIEGEL Backstage

Kontakt über Secure Drop

AFTONBLADET

Kontakta Aftonbladet med SecureDrop

The Guardian

The Guardian SecureDrop

Share stories with us securely and confidentially

WIRED

SecureDrop Leak Tool Produces a Massive Trove of Prison Docs

The Intercept confirms that its latest anonymous leak of secrets arrived through its use of SecureDrop, a WikiLeaks-like, Tor-based upload system.

SecureDrop at The Globe and Mail

In March of 2015, Toronto's Globe and Mail installed the first SecureDrop in Canada. In an article announcing the launch, *The Globe*'s editor-in-chief David Walmsley wrote, "SecureDrop is the 21st-century equivalent of the manila envelope. It provides you with an anonymous venue for relaying material you believe to be in the public interest and you have no other way to get it out publicly."[13]

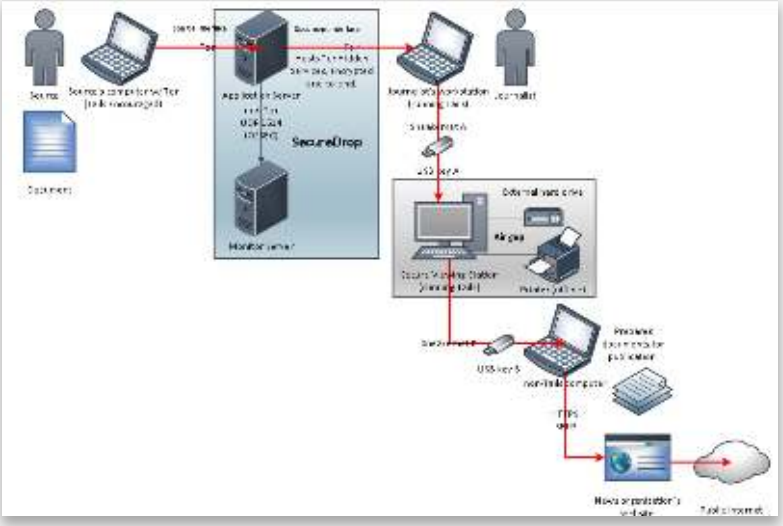
When asked if SecureDrop has been successful at *The Post*, Tate replied, "Definitely. I can't go into what those stories are. But we've had success with it, definitely."

forbidden stories

Killing the journalist won't kill the story.

SecureDrop 2013 - present

SecureDrop 2013 - present



- Physical on-premise servers
- Sources: Tor Browser, no JavaScript required
- PGP encryption at the server

Barriers to adoption

Responsibilities of SecureDrop administrators

As a SecureDrop administrator, it is your responsibility to:

- install SecureDrop
- manage users
- manage the system configuration
- ensure that servers, firewall and workstations are kept up-to-date
- monitor OSSEC alerts
- monitor the SecureDrop team's release and security-related communications
- apply available firmware updates to all SecureDrop hardware
- ensure that the SecureDrop environment is physically secure and monitored
- investigate and respond to security incidents
- schedule and perform required maintenance tasks, such as operating system upgrades
- ensure that SecureDrop users adhere to the documented processes for checking SecureDrop, communicating with sources, and reviewing documents
- verify the integrity of SecureDrop code
- avoid the installation of unsupported code or patches
- decommission SecureDrop after it is no longer in use

SecureDrop for Administrators.
https://docs.securedrop.org/

SecureDrop is on its way to reaching a primary goal of providing an exceptionally strong system, focused particularly on security and anonymity aspects. It is now reaching a moment when developing ways to work on accessibility and installation ease are vividly important. Discovering the best ways towards educating users to securely and safely

Heiderich et al (Cure53). Pentest-Report SecureDrop 12.2013.

- Deployment/maintenance burden
- Physical security requirement
- Better encryption is available

Barriers to adoption

Office of Nicaragua's *La Confidencial*, with editor Carlos Fernando Chamorro, in 2018 and 2021.
Image credits: Nayira Valenzuela (top), Alfredo Zuniga (right).

Next Generation SecureDrop: Requirements

Be “first contact” suitable

Support anonymous, confidential communication

Improve accessibility, lower cost

Respond to realistic threat models

Don’t reinvent the wheel

Don’t make life *worse* for sources

Next Generation SecureDrop: Requirements

Be “first contact” suitable	→ Async; sources don’t broadcast
Support anonymous, confidential communication	
Improve accessibility, lower cost	
Respond to realistic threat models	
Don’t reinvent the wheel	
Don’t make life *worse* for sources	

Next Generation SecureDrop: Requirements

Be “first contact” suitable	→ Async; sources don’t broadcast
Support anonymous, confidential communication	→ E2EE; Unobservability
Improve accessibility, lower cost	
Respond to realistic threat models	
Don’t reinvent the wheel	
Don’t make life *worse* for sources	

Next Generation SecureDrop: Requirements

Be “first contact” suitable	→ Async; sources don’t broadcast
Support anonymous, confidential communication	→ E2EE; Unobservability
Improve accessibility, lower cost	→ Cloud deployment possible
Respond to realistic threat models	
Don’t reinvent the wheel	
Don’t make life *worse* for sources	

Next Generation SecureDrop: Requirements

Be “first contact” suitable	→ Async; sources don’t broadcast
Support anonymous, confidential communication	→ E2EE; Unobservability
Improve accessibility, lower cost	→ Cloud deployment possible
Respond to realistic threat models	→ Small user base; minimize metadata
Don’t reinvent the wheel	
Don’t make life *worse* for sources	

Next Generation SecureDrop: Requirements

Be "first contact" suitable	→ Async; sources don't broadcast
Support anonymous, confidential communication	→ E2EE; Unobservability
Improve accessibility, lower cost	→ Cloud deployment possible
Respond to realistic threat models	→ Small user base; minimize metadata
Don't reinvent the wheel	→ Do we *have* to?
Don't make life *worse* for sources	

Next Generation SecureDrop: Requirements

Be “first contact” suitable	→ Async; sources don’t broadcast
Support anonymous, confidential communication	→ E2EE; Unobservability
Improve accessibility, lower cost	→ Cloud deployment possible
Respond to realistic threat models	→ Small user base; minimize metadata
Don’t reinvent the wheel	→ Do we *have* to?
Don’t make life *worse* for sources	⚠

Don’t make life *worse* for sources

- Don’t leave extra evidence behind
  - Avoid bespoke app, file persistence for sources

Don’t make life *worse* for sources

- Don’t leave extra evidence behind
  - Avoid bespoke app, file persistence for sources
- Don’t create incontrovertible proof
  - Protocol-level deniability measures

"We cannot design protocols that provide more deniability than plaintext; however, we can easily design protocols that provide less [...] [W]e should strive to design deniable protocols to avoid unintentionally incriminating users.”

Unger and Goldberg, *Deniable Key Exchanges for Secure Messaging*, 2015.

The Guardian

News | Opinion | Sport | Culture | Lifestyle

Monday briefing: The community solidarity driving the fightback against ICE in Minneapolis

Mutual aid groups first built during the pandemic have been reactivated to provide essentials to families sheltering in place. “People who are doing grocery runs are being told to not put any of the details in their phones, not to use GPS, to write the number and the address down on a piece of paper, and if they get stopped by ICE to eat it,” she says.

Deniability is a hot potato

- Users hold mixed mental models
  - Protocol-level deniability is convincing, but so are screenshots…
- Anonymity, metadata minimization are higher priority
- Deniability means tradeoffs

Is Cryptographic Deniability Sufficient?
Non-Expert Perceptions of Deniability in Secure Messaging

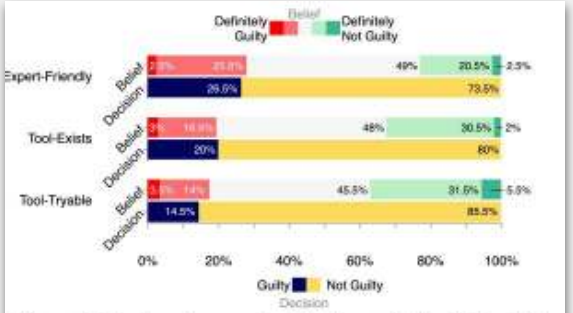


Figure 6: Fraction of respondents in **Survey 2** who believed the governor was guilty or not guilty (i.e., belief), and who returned a verdict of guilty or not guilty (i.e., decision).

Reitinger et al, 2023.

In essence, cryptographic deniability is theoretically sound, but its practical implications are weakened by real-world contexts and human factors that these models do not address.

Collins et al, *Real-World Deniability in Messaging*, 2023.

Next Generation SecureDrop: Requirements

Be "first contact" suitable	→ Async; sources don't broadcast
Support anonymous, confidential communication	→ E2EE; Unobservability
Improve accessibility, lower cost	→ Cloud deployment possible
Respond to realistic threat models	→ Small user base; minimize metadata
Don't reinvent the wheel	→ Do we *have* to?
Don't make life *worse* for sources	→ <u>No client-side state; include deniability measures</u>

SecureDrop is for some, but not all, sources

- Signal *is* appropriate in many cases; newsrooms are encouraged to be reachable via a variety of channels
- Our requirements impose tradeoffs …and lead us away from existing solutions

Forbidden Stories' SafeBox Tutorial, https://forbiddenstories.org/safebox/tutorial/

What About Existing Solutions?

Avoid client-side persistence (for sources) …rules out Signal (and many others)

Minimize information on the server …can we avoid accounts entirely?

Implicit authentication to preserve deniability …rules out non-repudiable protocols

Avoid HNDL, leaking ciphertext …rules out trial-decryption and non-PQ

Consider engineering practicality …robust libraries? Communication cost?

What About Existing Solutions?

Avoid client-side persistence (for sources) …rules out Signal (and many others)

Minimize information on the server …can we avoid accounts entirely?

Implicit authentication to preserve deniability …rules out non-repudiable protocols

Avoid HNDL, leaking ciphertext …rules out trial-decryption and non-PQ

Consider engineering practicality …robust libraries? Communication cost?

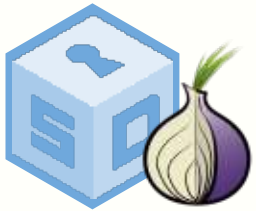
Research

https://securedrop.org/research

SecureDrop Protocol

Protocol Entities

Sources

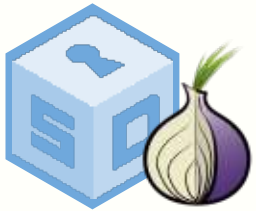


SecureDrop Server

Journalists

Protocol Entities

Sources



SecureDrop Server

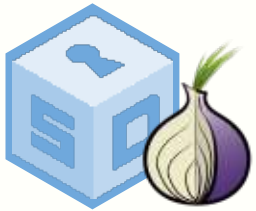
- Managed by a newsroom
- Just an encrypted message queue: no users tables, no accounts

Journalists

Protocol Entities

Sources

- Keys derived from mnemonic seed phrase
- Keys not advertised
- **No persistent state → no key rotation**
- Client is Tor browser



SecureDrop Server

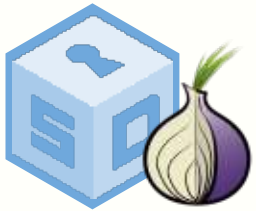
- Managed by a newsroom
- Just an encrypted message queue: no users tables, no accounts

Journalists

Protocol Entities

Sources

- Keys derived from mnemonic seed phrase
- Keys not advertised
- **No persistent state → no key rotation**
- Client is Tor browser



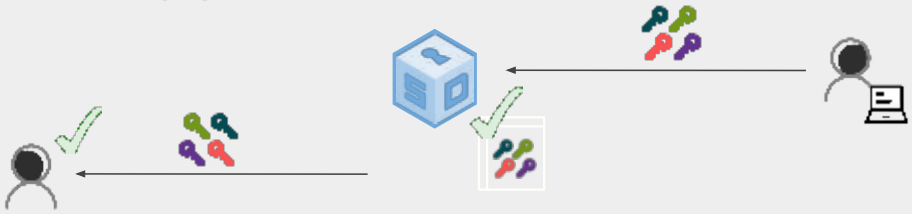
SecureDrop Server

- Managed by a newsroom
- Just an encrypted message queue: no users tables, no accounts

Journalists

- Keys publicly advertised
- **Persistent state → key rotation (one-time keys)**
- Client is local, stateful

Protocol At A Glance

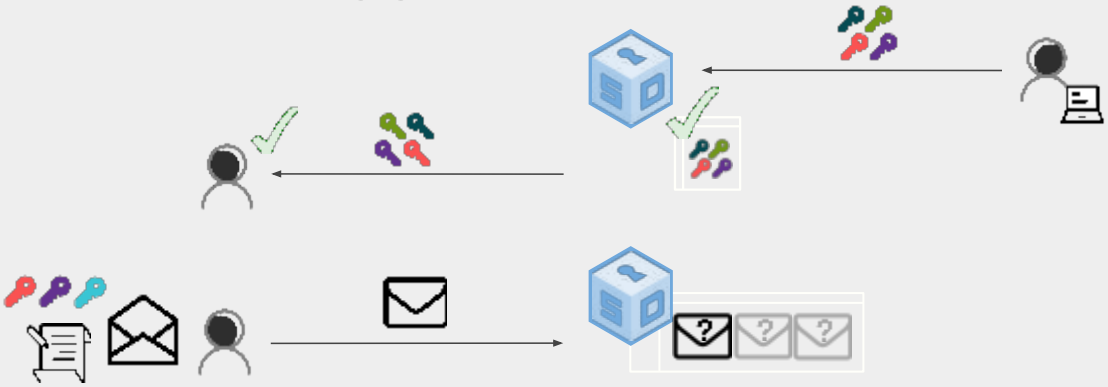


Journalist: Enrolls

Source: Requests journalist keys

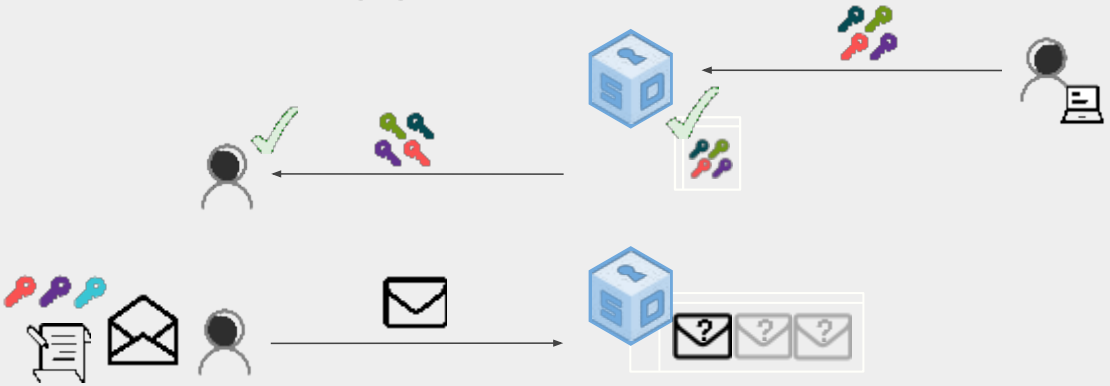
*details of journalist key authentication omitted

Protocol At A Glance

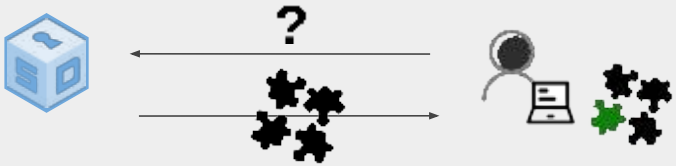


Source: submits message

Protocol At A Glance

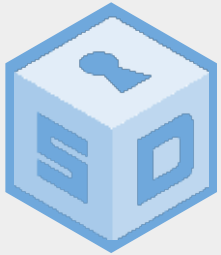


Journalist: checks for new messages by solving a challenge

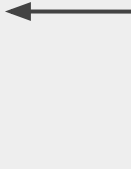


Journalist: retrieves and decrypts message, and can then reply

Protocol Overview: Enrollment



Journalist Enrollment: Upload long term public keys to server



DH Key

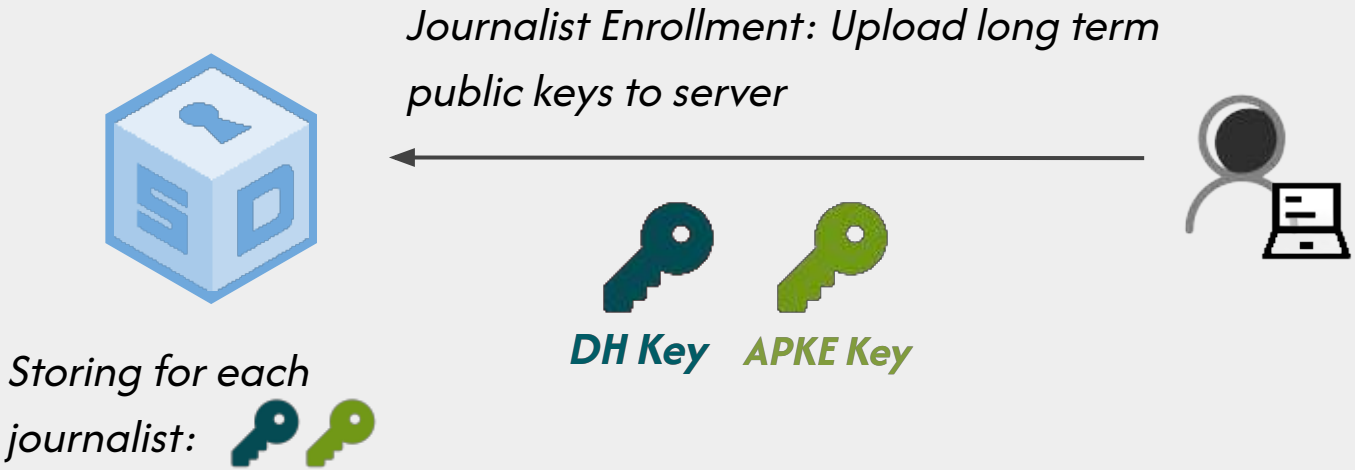
APKE Key

Message retrieval

Message encryption

*details of journalist key authentication omitted

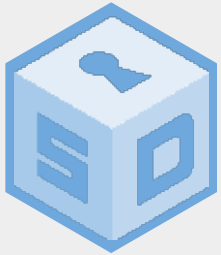
Protocol Overview: Enrollment



*details of journalist key authentication omitted

Protocol Overview: Key Upload

Journalist Key Bundles: Upload ephemeral public key bundles to server



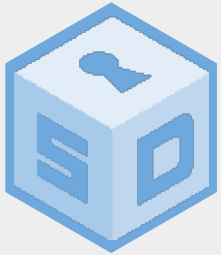
Storing for each journalist:

Ephemeral message keys

*details of journalist key authentication omitted

Protocol Overview: Key Upload

Journalist Key Bundles: Upload ephemeral public key bundles to server

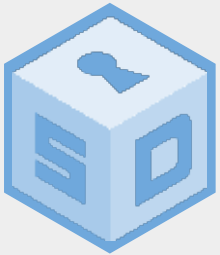


Storing for each journalist:

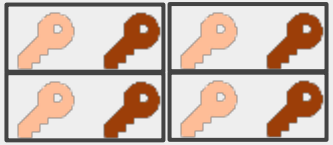
*details of journalist key authentication omitted

Protocol Overview: Key Retrieval

Retrieve keys for each journalist

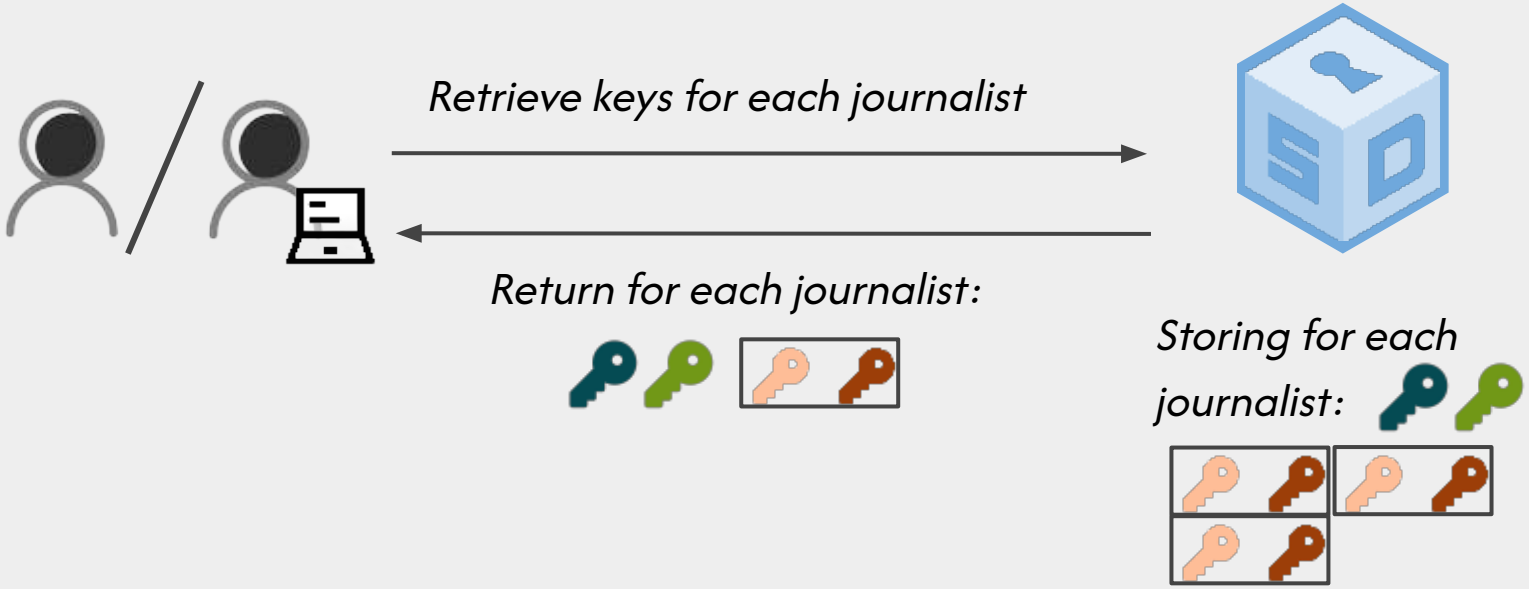


Storing for each journalist:



*details of journalist key authentication omitted

Protocol Overview: Key Retrieval

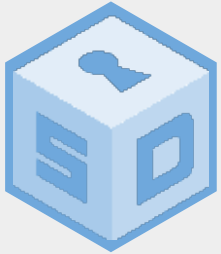


*details of journalist key authentication omitted

Protocol Overview: Message Sending

Sender keys (source):

Recipient keys (journalist):

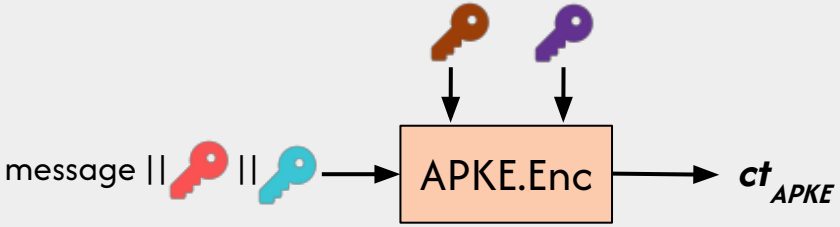


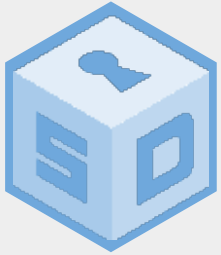
*illustrated from one source to journalist; simplified

Protocol Overview: Message Sending

Sender keys (source):

Recipient keys (journalist):



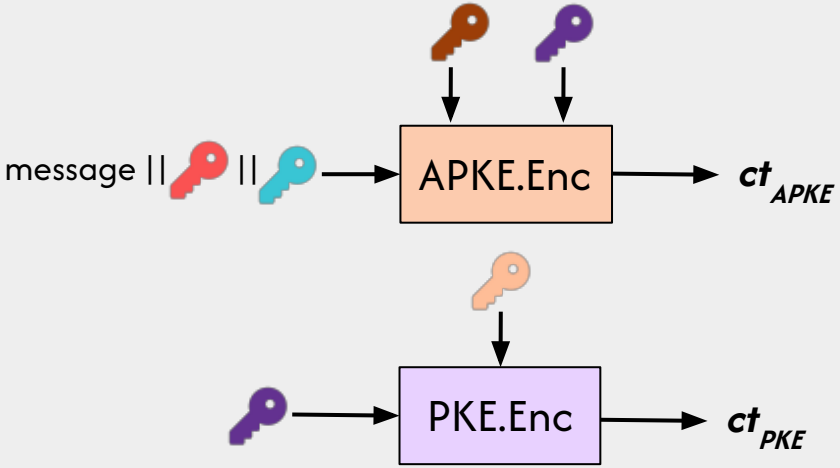


*illustrated from one source to journalist; simplified

Protocol Overview: Message Sending

Sender keys (source):

Recipient keys (journalist):

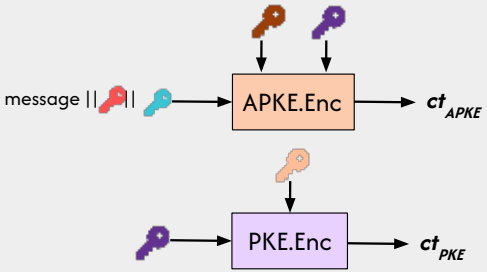


*illustrated from one source to journalist; simplified

Protocol Overview: Message Sending

Sender keys (source):

Recipient keys (journalist):

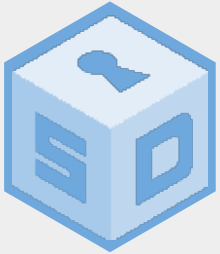


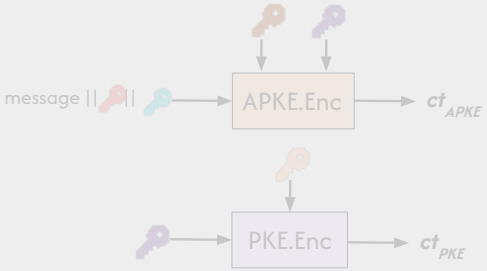
*illustrated from one source to journalist; simplified

Protocol Overview: Message Sending

Sender keys (source):

Recipient keys (journalist):



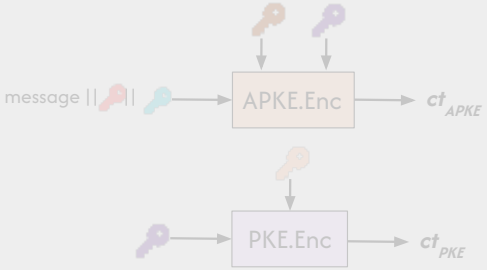


$X \leftarrow g^x, Z \leftarrow$ ^{x} $\quad ct_{APKE} \quad ct_{PKE}$

Serves as a "hint" to the recipient

*illustrated from one source to journalist; simplified

Protocol Overview: Message Sending



$X \leftarrow g^x, Z \leftarrow$ ^{x} $\quad ct_{APKE} \quad ct_{PKE}$

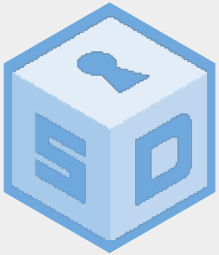
Serves as a "hint" to the recipient

Database of ciphertexts:

[id, X, Z, ct_{APKE}, ct_{PKE}]

*illustrated from one source to journalist; simplified

Protocol Overview: Message Retrieval



Database of ciphertexts:

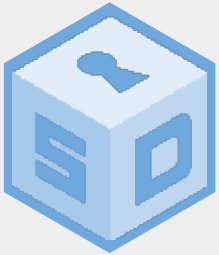
[id, X, Z, ct_{APKE}, ct_{PKE}]

Request messages

Recipient keys (journalist):

*illustrated from one source to journalist; simplified

Protocol Overview: Message Retrieval



Database of ciphertexts:

[id, X, Z, ct_{APKE}, ct_{PKE}]

Request messages

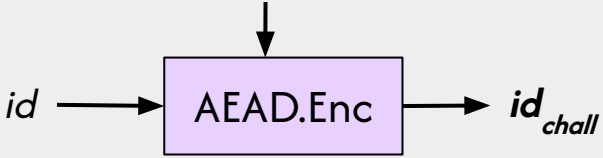
Recipient keys (journalist):

Prepare challenges:

$$\text{DH} \leftarrow g^{r}$$

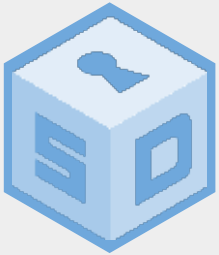
$$Q \leftarrow X^{r}$$

$$Z^{r} \; (= g^{x\,r\,y})$$



*illustrated from one source to journalist; simplified

Protocol Overview: Message Retrieval



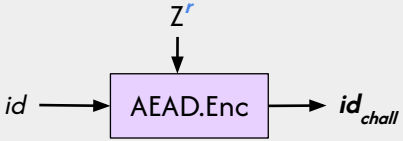
Database of ciphertexts:

[id, X, Z, ct_{APKE}, ct_{PKE}]

Prepare challenges:

$\xleftarrow{DH} g^r$

$Q \leftarrow X^r$



Request messages

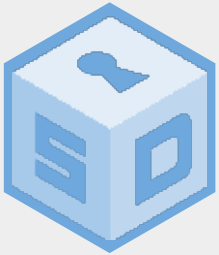
$[id_{chall}, Q]$

Send all challenges

Recipient keys (journalist):

*illustrated from one source to journalist; simplified

Protocol Overview: Message Retrieval



Database of ciphertexts:

[id, X, Z, ct_{APKE}, ct_{PKE}]

Prepare challenges:

$\xleftarrow{DH} g^r$

$Q \leftarrow X^r$

Z^r

id → AEAD.Enc → id_{chall}

Request messages ←

[id_{chall}, Q] →

Send all challenges

Recipient keys (journalist):

$= g^y$

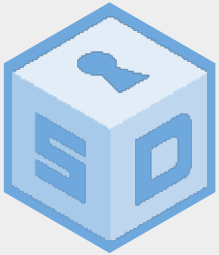
Trial decrypt challenges:

$Q^y \quad (= g^{xry})$

id_{chall} → AEAD.Dec → $id / \perp$

*illustrated from one source to journalist; simplified

Protocol Overview: Message Retrieval



Database of ciphertexts:

[id, X, Z, ct_{APKE}, ct_{PKE}]

Prepare challenges:

$\xleftarrow{DH} g^r$

$Q \leftarrow X^r$

Z^r

id → AEAD.Enc → id_{chall}

Request messages ←

[id_{chall}, Q] →

Send all challenges

← id

Recipient keys (journalist):

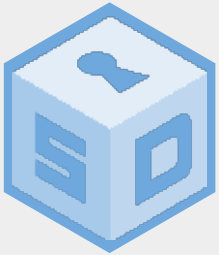
Trial decrypt challenges:

Q^y

id_{chall} → AEAD.Dec → id / ⊥

*illustrated from one source to journalist; simplified

Protocol Overview: Message Retrieval



Database of ciphertexts:

[id, X, Z, ct_{APKE}, ct_{PKE}]

Prepare challenges:

$\xleftarrow{DH} g^r$

$Q \leftarrow X^r$

Z^r

id → AEAD.Enc → id_{chall}

Request messages

[id_{chall}, Q]

Send all challenges

id

[ct_{APKE}, ct_{PKE}]

Recipient keys (journalist):

Trial decrypt challenges:

Q^y

id_{chall} → AEAD.Dec → id / ⊥

*illustrated from one source to journalist; simplified

Discussion

Notable Properties

- Stateless sender (source) to stateful recipient (journalist)
- Simple API: **`/getkeys, /sendmessage, /getchallenges, /getmessage`**
- No concept of "users" or user accounts on the server
  - No pending messages for a source → response same as for non-user
  - Still, ciphertexts are *not* broadcast + trial-decrypted

Notable Properties

- Stateless sender (source) to stateful recipient (journalist)
- Simple API: **`/getkeys, /sendmessage, /getchallenges, /getmessage`**
- No concept of "users" or user accounts on the server
  - No pending messages for a source → response same as for non-user
  - Still, ciphertexts are *not* broadcast + trial-decrypted
- No forward secrecy for messages to sources ⚠️
- Message encryption is PQ but implicit auth is classical DH-AKEM ⚠️

Security Analysis

	Threat Model	Proofs
Confidentiality	Active Server	
Authentication	Active Server	
Anonymity	Passive Server	

Computational (pen-and-paper) proofs: primarily for primitive-level properties, as well as for anonymity

Symbolic (Tamarin) proofs: for protocol-level properties

Deployment considerations

Organizational Profiles

Organizational Profiles

Org. A: Prominent int'l news organization, multiple offices in different cities, int'l investigations and leaks.

Organizational Profiles

Org. A: Prominent int'l news organization, multiple offices in different cities, int'l investigations and leaks.

Recommendation:
Self-hosting

Organizational Profiles

Org. A: Prominent int'l news organization, multiple offices in different cities, int'l investigations and leaks.

Org. B: Small news organization, investigates local corruption; low press freedom index jurisdiction.

Recommendation:
Self-hosting

Organizational Profiles

Org. A: Prominent int'l news organization, multiple offices in different cities, int'l investigations and leaks.

Org. B: Small news organization, investigates local corruption; low press freedom index jurisdiction.

Recommendation:
Self-hosting

Recommendation:
Cloud deployment, consider provider jurisdiction

Organizational Profiles

Org. A: Prominent int'l news organization, multiple offices in different cities, int'l investigations and leaks.

Org. B: Small news organization, investigates local corruption; low press freedom index jurisdiction.

Org. C: Independent investigative collective; risk profile of A, resources of B.

Recommendation:
Self-hosting

Recommendation:
Cloud deployment, consider provider jurisdiction

Organizational Profiles

Org. A: Prominent int'l news organization, multiple offices in different cities, int'l investigations and leaks.

Org. B: Small news organization, investigates local corruption; low press freedom index jurisdiction.

Org. C: Independent investigative collective; risk profile of A, resources of B.

Recommendation:
Self-hosting

Recommendation:
Cloud deployment, consider provider jurisdiction

Recommendation:
Case by case

Next steps

FREEDOM OF THE PRESS FOUNDATION

Coming soon…

- Attachments specification
- Formal verification with Hax
- In parallel: freedomofpress/webcat

HAX

Questions?

{ro, cory, giulio}@freedom.press

{shannon.veitch, flinker, kenny.paterson}@inf.ethz.ch

freedomofpress/securedrop-protocol

freedomofpress/securedrop-protocol-models

Acknowledgments

@TheZ3ro @smaury

@eaon @redshiftzero

And: All of our colleagues

Journalists and media organizations seeking to hold power to account

Newsroom IT staff, for your patience

Sources, for your courage and convictions